

Showing that you care about security for your open source (hardware) project

OSHcamp - Aug 2024



openssf scorecard 8.2



OpenSSF Scorecards

Following the example set by [Dart and Flutter](#) we've implemented [Open Source Security Foundation Scorecards](#) on key repos:

Repo	OpenSSF scorecard	Chart
at_c	openssf scorecard 8.8	
at_client_sdk	openssf scorecard 8.4	
at_demos	openssf scorecard 8.6	
at_esp32	openssf scorecard 8.9	
at_java	openssf scorecard 8.1	
at_libraries	openssf scorecard 8.4	
at_protocol	openssf scorecard 8.6	
at_pico_w	openssf scorecard 8.5	
at_python	openssf scorecard 9.1	
at_rust	openssf scorecard 8.5	
at_server	openssf scorecard 8.9	
at_tools	openssf scorecard 8.6	
at_widgets	openssf scorecard 8.6	
dess	openssf scorecard 8.4	
docs	openssf scorecard 7.4	
noports	openssf scorecard 9.2	



The software supply chain trifecta



Hi, I'm Chris

@cpswan

<https://chris.swanz.net>



Agenda

- Gathering our ingredients - SBOM
- Precise preparation - SLSA
- Ensuring kitchen hygiene - Scorecard





OpenSSF

OPEN SOURCE SECURITY FOUNDATION

<https://openssf.org/>



Software Bill of Materials - SBOM



<https://www.cisa.gov/sbom>

Executive Order 14028

THE WHITE HOUSE



MAY 12, 2021

Executive Order on Improving the Nation's Cybersecurity



BRIEFING ROOM



PRESIDENTIAL ACTIONS



Two competing standards :(

 CycloneDX
ECMA-424

 OWASP®



 **SPDX**

 **OpenSSF**
OPEN SOURCE SECURITY FOUNDATION



*"There can be no peace until they renounce their
Rabbit God and accept our Duck God."*

Make the SBOM with Syft, understand it with GUAC



syft

<https://github.com/anchore/syft>



GUAC

<https://guac.sh/>



Generating Software Bill of Materials (SBOM)

```
- name: Checkout pubspec.lock
  uses: actions/checkout@44c2b7a8a4ea60a981eaca3cf939b5f4305c123b # v4.1.5
  with:
    sparse-checkout: packages/dart/sshnoports/pubspec.lock
    sparse-checkout-cone-mode: false
- name: Install Syft
  uses: anchore/sbom-action/download-syft@7ccf588e3cf3cc2611714c2eeae48550fbc17552
- name: Generate SBOMs
  run: |
    syft scan file:./packages/dart/sshnoports/pubspec.lock \
      -o 'spdx-json=tarballs/dart_sshnoports_sbom.spdx.json' \
      -o 'cyclonedx-json=tarballs/dart_sshnoports_sbom.cyclonedx.json'
```

Easy if you're using a modern package managed language. Not so much with traditional embedded...



CONAN
C/C++ package manager

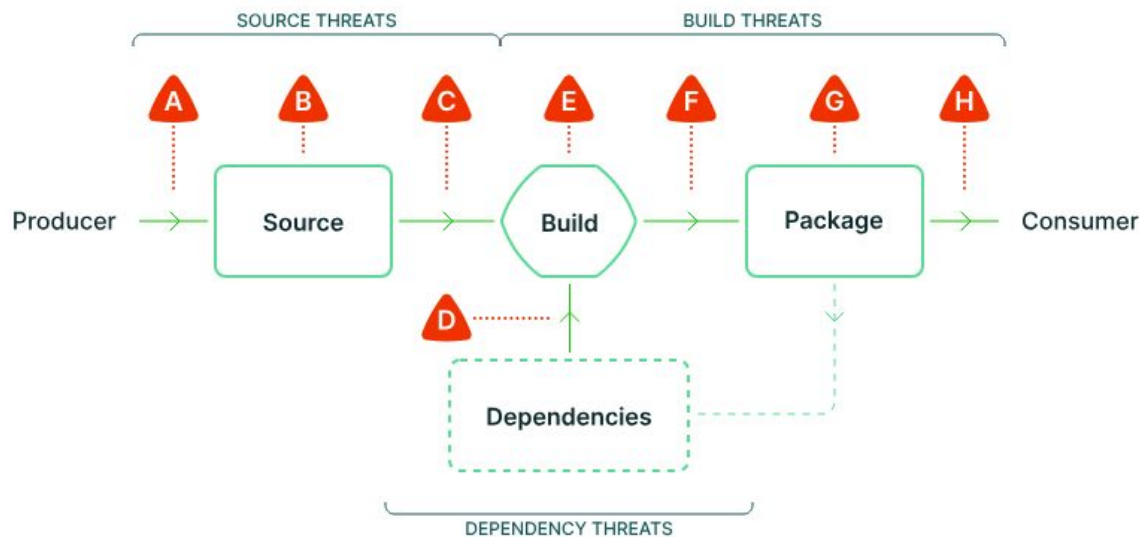


Supply-chain Levels for Software Artifacts - SLSA



<https://slsa.dev/>

Supply chain threats



SOURCE THREATS

- A** Submit unauthorized change
- B** Compromise source repo
- C** Build from modified source

DEPENDENCY THREATS

- D** Use compromised dependency

BUILD THREATS

- E** Compromise build process
- F** Upload modified package
- G** Compromise package registry
- H** Use compromised package



SLSA Build Levels

Track/Level	Requirements	Focus
Build L0	(none)	(n/a)
Build L1	Provenance showing how the package was built	Mistakes, documentation
Build L2	Signed provenance, generated by a hosted build platform	Tampering after the build
Build L3	Hardened build platform	Tampering during the build



<https://slsa.dev/spec/v1.0/levels>

Generate hashes and build attestation

```
- name: Generate SHA256 checksums
  working-directory: tarballs
  run: sha256sum * > checksums.txt
- id: hash
  name: Pass artifact hashes for SLSA provenance
  working-directory: tarballs
  run: |
    echo "hashes=$(cat checksums.txt | base64 -w0)" >> "$GITHUB_OUTPUT"
- uses: actions/attest-build-provenance@f8d5ea8082b0d9f5... # v1.1.0
  with:
    subject-path: 'tarballs/**'
```



In the GitHub Actions run for a build:

Upload artifacts and generate SBOMs and checksums for provenance summary ...

Attestations Created

[checksums.txt@sha256:3f2b09c91be0768862642153bf9479c8f1ff45a16475249a6fca4c17091dcda5](#)

[dart_sshnoports_sbom.cyclonedx.json@sha256:017532bc7a01a0249211819be5858bc76cf4db7824e0e6432dd0831983948094](#)

[dart_sshnoports_sbom.spdx.json@sha256:013bff32cd7c776e54c36db692aceadce13d28839c06ec1b8ed23421edf305e1sshnp-linux-arm.tgz@sha256:c01db8b68b97137f58d2316bd7671c697a92886f5bbca7d1e786a937395adcd8sshnp-linux-arm64.tgz@sha256:73d7a35749d7a6a3e49dbe54185c4f5883a75661a06ae7e72aa091094ad7b538sshnp-linux-riscv64.tgz@sha256:9599c393267123ad2fce202e003c5c16dd61ec6b1a0ddc4fb4841897e89e9970sshnp-linux-x64.tgz@sha256:149390a9bfddf1ef20b0422e8ac7ac2ce9ced23d15a6f5198274e8c631102cccsshnp-macos-arm64.zip@sha256:169d2a531a111af84751cb9a86b8f923de31b3dd9b615e0bf8a561538df0ee35sshnp-macos-x64.zip@sha256:0646e224b9e1bda2f61b4a325b17d20f5e02dd91337fa7642c944f899652f29dsshnp-windows-x64.zip@sha256:42ba16b7ba9a29ef931f393c52862619dd6342b422eb846bdc733abe2c400e10universal.sh@sha256:1fc12801024c5c120a27c6daa82f093d6419d79e35eb9d0eb6ae52ff764c6aca](#)

Job summary generated at run-time



Clicking through to an attestation

← Attestations

 sshnp-linux-arm.tgz

[View build summary](#)

 Download

Created	last month (Fri, 10 May 2024 15:35:03 GMT)
Commit	fac5eec16065a1200097956d86ba057d1fa52944
Subject Digest	sha256:c01db8b68b97137f58d2316bd7671c697a9288... 
Predicate Type	https://slsa.dev/provenance/v1
Workflow	.github/workflows/multibuild.yaml@refs/tags/v5.2.1-rc1
Build Trigger	push
Verify	<code>gh attestation verify <filename-or-url> --owner atsign-foundation --bundle ./atsign-foundation-noports-attestation-822137.sigstore.json</code>



Use hashes to create a SLSA attestation

```
provenance:
  needs: [github-release]
  permissions:
    actions: read # Needed for detection of GitHub Actions environment.
    id-token: write # Needed for provenance signing and ID
    contents: write # Needed for release uploads
  uses: slsa-framework/slsa-github-generator/.github/workflows/generator_generic_slsa3.yml@v2.0.0
  with:
    base64-subjects: "${{ needs.github-release.outputs.hashes }}"
    upload-assets: true
```



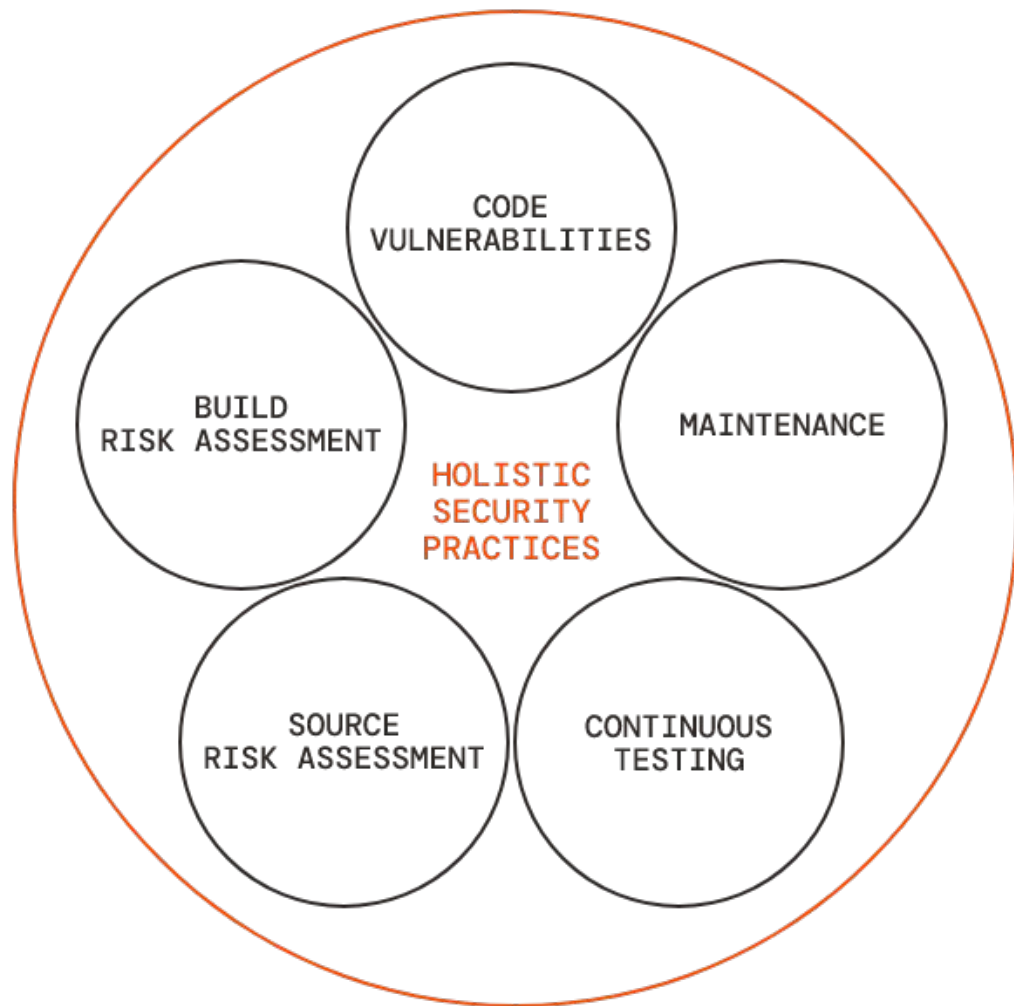
Peeking inside multiple.intoto.jsonl

```
{
  "_type": "https://in-toto.io/Statement/v0.1",
  "predicateType": "https://slsa.dev/provenance/v0.2",
  "subject": [
    {
      "name": "dart_sshnoports_sbom.cyclonedx.json",
      "digest": {
        "sha256": "017532bc7a01a0249211819be5858bc76cf4db7824e0e6432dd0831983948094"
      }
    },
    {
      "name": "dart_sshnoports_sbom.spdx.json",
      "digest": {
        "sha256": "013bff32cd7c776e54c36db692aceadce13d28839c06ec1b8ed23421edf305e1"
      }
    }
  ],
}
```

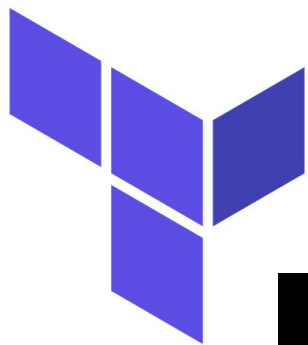


Scorecard

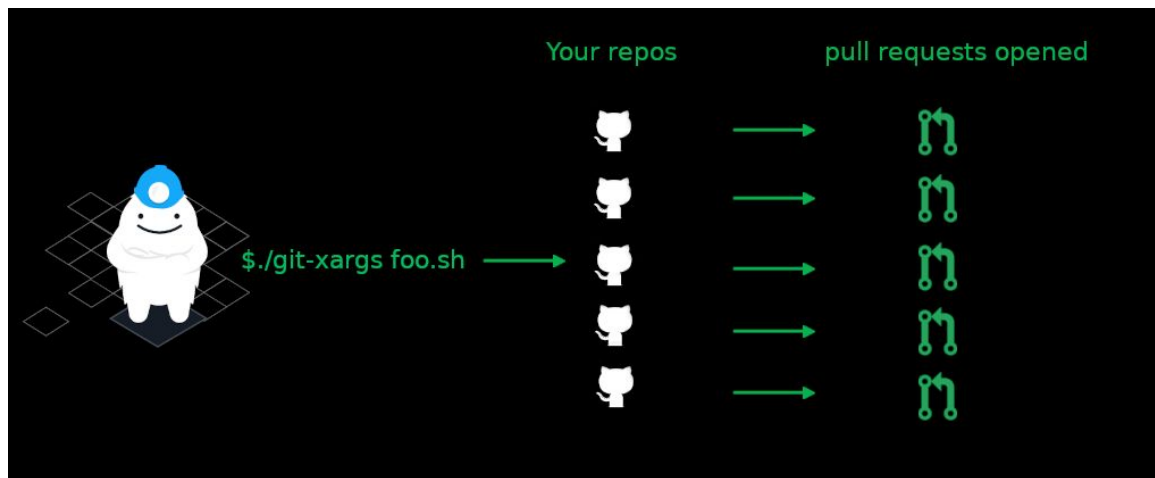




A whole bunch of config, and a whole bunch of files



Terraform



Expect LOTS of issues

The screenshot shows a list of GitHub Actions workflow runs. The top bar indicates '128 Closed' runs. The list includes:

- Branch-Protection** (High): #5 closed as won't fix 6 months ago. Detected by Scorecard in no file associated with
- Token-Permissions** (High): #125 closed as fixed 6 months ago. Detected by Scorecard in .github/workflows/ve_base.yaml.
- Token-Permissions** (High): #123 closed as fixed 6 months ago. Detected by Scorecard in .github/workflows/refreshcerts.yaml.
- Token-Permissions** (High): #124 closed as fixed 6 months ago. Detected by Scorecard in .github/workflows/revert_secondary.yaml.
- Token-Permissions** (High): #122 closed as fixed 6 months ago. Detected by Scorecard in .github/workflows/promote_canary.yaml.
- Pinned-Dependencies** (Medium): #128 closed as won't fix 6 months ago. Detected by Scorecard in tools/.../ve/Dockerfile.canary_to_vip.

A large red box highlights the word 'Closed' in the top bar, and another red box highlights the '128 Closed' status in the top bar.



Help is at hand



Apply Security Best Practices

☆ Star

189

- ☒ Restrict permissions for GITHUB_TOKEN
- ☐ Add security agent for GitHub-hosted runner
- ☒ Pin actions to a full length commit SHA

Paste your GitHub Actions workflow in the editor below, click this button, and then copy the output

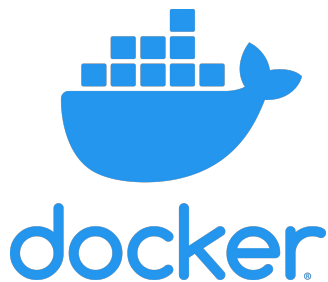
➔ SECURE WORKFLOW

📄 CREATE A PULL REQUEST



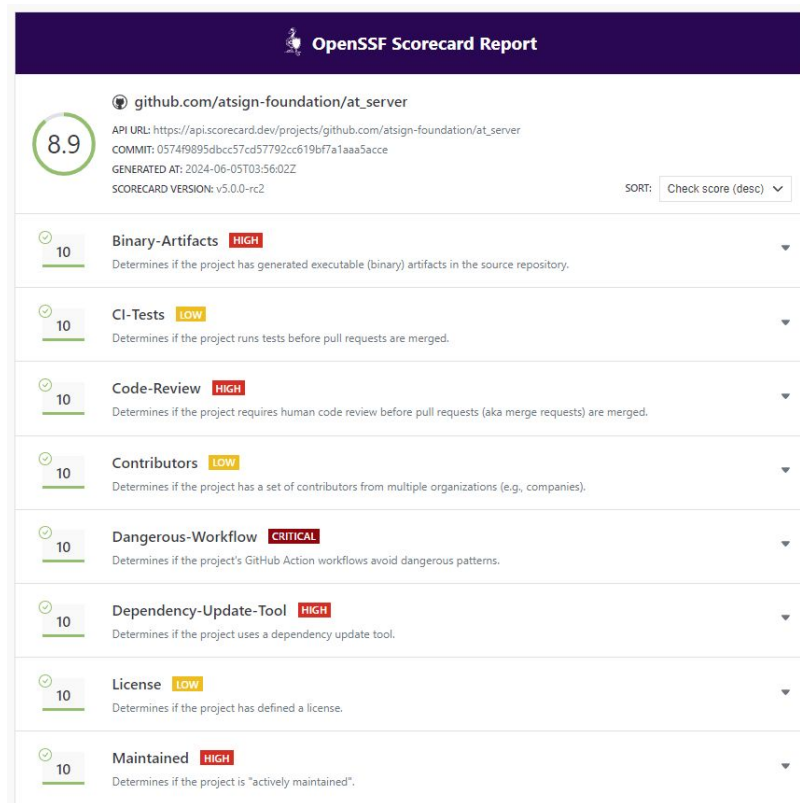
```
11+ permissions: # added using https://github.com/step-security/secure-repo
12+ contents: read
13+
14 jobs:
15   build_multi_arch_images:
16     runs-on: ubuntu-latest
17     steps:
18       - name: Check out code
19         uses: actions/checkout@v3
20         uses: actions/checkout@8e5e7e5ab8b370d6c329ec480221332ada57f0ab # v3.5.2
21       - name: Set up QEMU
22         uses: docker/setup-qemu-action@v2.1.0
23         uses: docker/setup-qemu-action@e81a89b1732b9c48d79cd809d8d81d79c4647a18 # v2.1.0
24       - name: Set up Docker Buildx
25         uses: docker/setup-buildx-action@v2.5.0
26         uses: docker/setup-buildx-action@4b4e9c3e2d4531116a6f8ba8e71fc6e2cb6e6c8c # v2.5.0
27       - name: Login to DockerHub
28         uses: docker/login-action@v2.1.0
29         uses: docker/login-action@f4ef78c080cd8ba55a85445d5b36e214a81df20a # v2.1.0
30       with:
31         username: ${{ secrets.DOCKERHUB_USERNAME }}
32
33 ✓ Minimum GITHUB_TOKEN permissions have been set. [Learn more]
34 ✓ GitHub Actions have been pinned to their full length commit SHA. [Learn more]
35 ✓ Permissions already defined at the workflow level.
```

Dependency (pinning) hell cont...



80:20

It's relatively easy to get most stuff right



There will be a residue

☐  3 Open ☒ 2 Closed		Tool ▾ Branch ▾ Rule ▾ Severity ▾ Sort ▾			
☐		SAST	Medium		trunk
#4 opened 5 months ago • Detected by Scorecard in no file associated with1					
☐		Fuzzing	Medium		trunk
#3 opened 5 months ago • Detected by Scorecard in no file associated with1					
☐		CII-Best-Practices	Low		trunk
#2 opened 5 months ago • Detected by Scorecard in no file associated with1					



How this looks to your users

 9	Pinned-Dependencies MEDIUM	Determines if the project has declared and pinned the dependencies of its build process.	▼
 5	Branch-Protection HIGH	Determines if the default and release branches are protected with GitHub's branch protection settings.	▼
 5	CII-Best-Practices LOW	Determines if the project has an OpenSSF (formerly CII) Best Practices Badge.	▼
 0	Fuzzing MEDIUM	Determines if the project uses fuzzing.	▼
 ?	Signed-Releases HIGH	Determines if the project cryptographically signs release artifacts.	▼

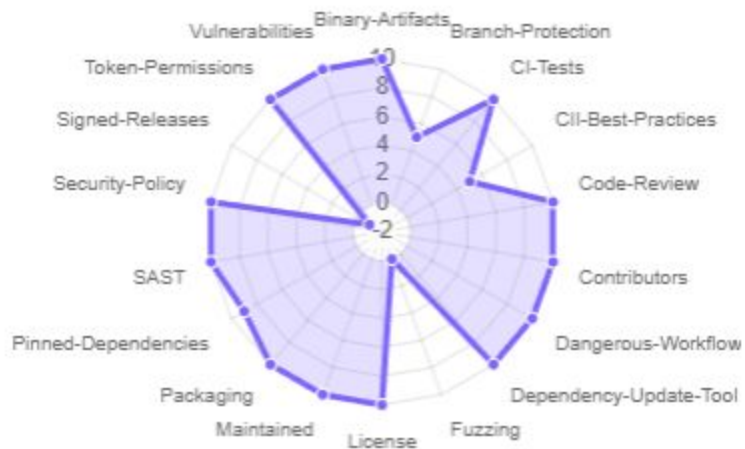


Radar plot

Scorecard Results

Overall Score: 8.9

Checks



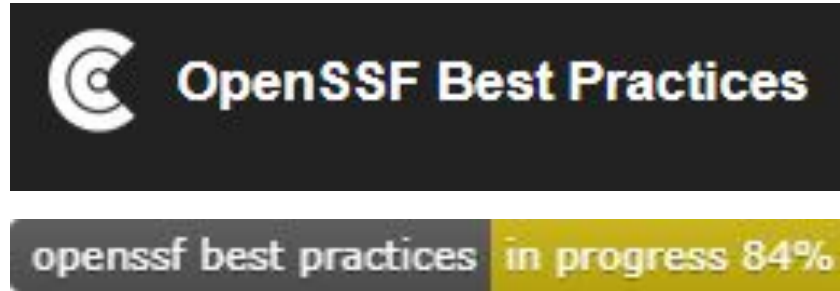
Static analysis with osv-scanner

steps:

- uses: actions/checkout@a5ac7e51b41094c92402da3b24376905380afc29 # v4.1.6
- uses: dart-lang/setup-dart@f0ead981b4d9a35b37f30d36160575d60931ec30 # v1.6.4
with:
 - sdk: stable
- uses: actions/setup-go@cdcb36043654635271a94b9a6d1392de5bb323a7 # v5.0.1
with:
 - go-version: 'stable'
 - cache-dependency-path: tools/osv-scanner/go.sum
- name: Run osv-scanner
working-directory: packages/\${{ matrix.package }}
run: |
 - dart pub get
 - go install github.com/google/osv-scanner/cmd/osv-scanner@6316373e47d...
 - osv-scanner --lockfile=./pubspec.lock



This is where it gets really gnarly



▼ Basics	13/13 ●
▼ Change Control	8/9 ●
▼ Reporting	8/8 ●
▼ Quality	11/13 ●
▼ Security	14/16 ●
▼ Analysis	2/8 ●



The questionnaire is long and detailed

New functionality testing



- ☐ Met
☐ Unmet
☐ ?

The project MUST have a general policy (formal or not) that as major new functionality is added to the software produced by the project, tests of that functionality should be added to an automated test suite. [\[test_policy\]](#) [Show details](#)



- ☐ Met
☒ Unmet
☐ ?

The project MUST have evidence that the [test_policy](#) for adding tests has been adhered to in the most recent major changes to the software produced by the project. [\[tests_are_added\]](#) [Show details](#)



- ☐ Met
☒ Unmet
☐ ?

It is SUGGESTED that this policy on adding tests (see [test_policy](#)) be *documented* in the instructions for change proposals. [\[tests_documented_added\]](#) [Show details](#)



And some sections might be hard to accomplish

Dynamic code analysis



- ☐ Met
- ☐ Unmet
- ☒ ?

It is SUGGESTED that at least one dynamic analysis tool be applied to any proposed major production release of the software before its release. [\[dynamic_analysis\]](#) [Show details](#)



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

It is SUGGESTED that if the software produced by the project includes software written using a memory-unsafe language (e.g., C or C++), then at least one dynamic tool (e.g., a fuzzer or web application scanner) be routinely used in combination with a mechanism to detect memory safety problems such as buffer overwrites. If the project does not produce software written in a memory-unsafe language, choose "not applicable" (N/A). [\[dynamic_analysis_unsafe\]](#) [Show details](#)



- ☐ Met
- ☐ Unmet
- ☒ ?

It is SUGGESTED that the project use a configuration for at least some dynamic analysis (such as testing or fuzzing) which enables many assertions. In many cases these assertions should *not* be enabled in production builds. [\[dynamic_analysis_enable_assertions\]](#) [Show details](#)



- ☐ Met
- ☐ Unmet
- ☐ N/A
- ☒ ?

All medium and higher severity exploitable vulnerabilities discovered with dynamic code analysis MUST be fixed in a timely way after they are confirmed. [\[dynamic_analysis_fixed\]](#) [Show details](#)



The toil of it all

Make friends with the new boss



From a docs repo (no actual code to maintain)

- ☐  **build(deps): bump actions/checkout from 3.5.1 to 3.5.2** ✓ dependencies
#71 by dependabot  was merged on Apr 13 • Approved
- ☐  **build(deps): bump github/codeql-action from 2.2.11 to 2.2.12** ✓ dependencies
#70 by dependabot  was merged on Apr 13 • Approved
- ☐  **build(deps): bump actions/checkout from 3.5.0 to 3.5.1** ✓ dependencies
#69 by dependabot  was merged on Apr 12 • Approved
- ☐  **build(deps): bump github/codeql-action from 2.2.10 to 2.2.11** ✓ dependencies
#68 by dependabot  was merged on Apr 7 • Approved
- ☐  **build(deps): bump github/codeql-action from 2.2.9 to 2.2.10** ✓ dependencies
#67 by dependabot  was merged on Apr 5 • Approved



From a code repo

- ☐  build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_secondary ✓ dependencies docker
#1193 by dependabot (bot) was merged on Feb 9 • Review required
- ☐  build(deps): bump dart from 2.19.1 to 2.19.2 in /packages/at_root_server ✗ dependencies docker
#1192 by dependabot (bot) was merged on Feb 9 • Review required
- ☐  build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_virtual_environment/ve ✗ dependencies docker
#1191 by dependabot (bot) was merged on Feb 9 • Review required
- ☐  build(deps): bump dart from 2.19.1 to 2.19.2 in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1190 by dependabot (bot) was merged on Feb 9 • Review required
- ☐  build(deps): bump github/codeql-action from 2.2.2 to 2.2.3 ✓ dependencies github_actions
#1189 by dependabot (bot) was merged on Feb 9 • Approved
- ☐  build(deps): bump github/codeql-action from 2.2.1 to 2.2.2 ✓ dependencies github_actions
#1188 by dependabot (bot) was merged on Feb 7 • Approved
- ☐  build(deps): bump docker/setup-buildx-action from 2.4.0 to 2.4.1 ✓ dependencies github_actions
#1187 by dependabot (bot) was merged on Feb 7 • Approved
- ☐  build(deps): bump debian from bullseye-20230109 to bullseye-20230202 in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1186 by dependabot (bot) was merged on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1185 by dependabot (bot) was merged on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /packages/at_root_server ✓ dependencies docker
#1184 by dependabot (bot) was closed on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_virtual_environment/ve ✓ dependencies docker
#1183 by dependabot (bot) was closed on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_secondary ✓ dependencies docker
#1182 by dependabot (bot) was closed on Feb 6 • Review required
- ☐  build(deps): bump google-github-actions/setup-gcloud from 1.0.1 to 1.1.0 ✗ dependencies github_actions
#1181 by dependabot (bot) was merged on Feb 6 • Approved



Scorecard's own dependencies can change with annoying regularity (in every repo with a scorecard)

☐  build(deps): bump github/codeql-action from 2.2.2 to 2.2.3 ✓ dependencies github_actions
#1189 by dependabot  was merged on Feb 9 • Approved

☐  build(deps): bump github/codeql-action from 2.2.1 to 2.2.2 ✓ dependencies github_actions
#1188 by dependabot  was merged on Feb 7 • Approved



Base dependencies can be amplified

- ☐  build(deps): bump debian from bullseye-20230109 to bullseye-20230202 in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1186 by dependabot bot was merged on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_virtual_environment/ve_base ✓ dependencies docker
#1185 by dependabot bot was merged on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /packages/at_root_server ✓ dependencies docker
#1184 by dependabot bot was closed on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_virtual_environment/ve ✓ dependencies docker
#1183 by dependabot bot was closed on Feb 6 • Review required
- ☐  build(deps): bump dart from 4c77cf9 to 86d317e in /tools/build_secondary ✓ dependencies docker
#1182 by dependabot bot was closed on Feb 6 • Review required

Use the directories and groups

```
- package-ecosystem: "pub"
  directories:
    - "/packages/dart/sshnoports/"
    - "/packages/dart/sshnp_flutter/"
  schedule:
    interval: "daily"
  groups:
    pub:
      patterns:
        - "*"

```



It might still help to do rollups: rollup.sh

```
#!/bin/bash
if [ $# -ne 2 ] ; then
    echo "Usage rollup.sh <BASE_PR> <LAST_PR>"
    exit 1
fi
BASE_PR=$1
LAST_PR=$2
git pull
gh pr checkout "$BASE_PR"
for (( i=$((BASE_PR + 1)); i<=LAST_PR; i++ ))
do
    PR_BRANCH=$(gh pr view "$i" --json headRefName -q .headRefName)
    git merge origin/"$PR_BRANCH" -m \
        "build(deps): Rollup merge branch for #${i} ${PR_BRANCH}"
done
git push
```



Review

- SBOM - knowing that you have the right ingredients
- SLSA - showing that there's care in preparation
- Scorecard - ensuring kitchen hygiene



Call to action: Run the scorecard CLI against one of your own repos

[https://github.com/ossf/scorecard#
scorecard-command-line-interface](https://github.com/ossf/scorecard#scorecard-command-line-interface)



Resources

Blog posts

<https://blog.thestateofme.com/2024/07/22/supply-chain-security-trifecta-sbom-slsa-scorecard/>

<https://blog.thestateofme.com/2022/12/02/implementing-ossf-scorecards-across-a-github-organisation/>

<https://blog.thestateofme.com/2023/03/09/roll-up-rollup-get-your-dependabot-prs-together-here/>

atGitHub

<https://github.com/at-sign-foundation/github/blob/trunk/docs/atGitHub.md>



Varun Sharma's (Step Security) QCon Demo Org

<https://github.com/qcon-demo-org>



Thanks for your time

chris@atsign.com

@cpswan



Questions?